Cloud Shift Data Security and Complaince Framework

Document ID: 001 **Version:** 1.0

Table of Contents

PART 1: GOVERNANCE & STRATEGY 4
1.0 INTRODUCTION 4
1.1 PURPOSE AND LEGAL MANDATE 4
1.2 SCOPE AND APPLICABILITY 4
1.3 REGULATORY HIERARCHY AND ALIGNMENT 4
2.0 Governance Structure 5
2.1 Roles & Responsibilities 5
2.2 The Privacy & Security Committee 5
2.3 Annual Review & Audit Cycle 5
2.4 Metrics and Control Monitoring 6
3.0 Data Classification Strategy 6
3.1 Data Classification Levels 6
3.2 Data Sovereignty Principles (Canada vs. US vs. EU Residency) 7
PART 2: THE POLICY MANUAL 9
4.0 Domain A: Privacy & Legal Compliance 9
4.1 **Policy 01:** Data Privacy Policy (External & Internal) 9
4.2 **Policy 02:** Data Retention & Destruction Policy 12
4.3 **Policy 03:** Third-Party & Vendor Risk Management Policy 14
5.0 Domain B: Information Security (InfoSec) 17
5.1 **Policy 04:** Information Security Policy (Master Policy) 17
5.2 **Policy 05:** Access Control & Identity Management Policy 20
5.3 **Policy 06:** Incident Response & Breach Notification Policy 24
5.4 **Policy 07:** Remote Access & Work-From-Home (WFH) Policy 27
6.0 Domain C: Product & Service Operations 30
6.1 **Policy 08:** Secure Software Development Lifecycle (SSDLC) Policy 30
6.2 **Policy 09:** Change Management & Deployment Policy 33
6.3 **Policy 10:** Acceptable Use Policy (AUP) 36
6.4 **Policy 11:** Business Continuity & Disaster Recovery Policy 40

6.5 **Policy 12**: Digital Accessibility & Inclusion Policy 44
PART 3: PROCEDURES REGISTRY (APPENDICES) 46
7.0 Technical Standards Registry 46
8.0 Operational Playbooks 46
9.0 Forms & Templates 47
10.0 Acronyms 47

PART 1: GOVERNANCE & STRATEGY

1.0 INTRODUCTION

1.1 PURPOSE AND LEGAL MANDATE

The *Cloud Shift Data Security & Compliance Framework* (hereinafter the "Framework") serves as the primary governance instrument for Cloud Shift Inc. and its subsidiaries. Its purpose is to codify the organization's legal, ethical, and technical obligations regarding the processing of Data Assets.

This Framework translates statutory requirements, specifically the *Personal Information Protection and Electronic Documents Act* (PIPEDA), the *General Data Protection Regulation* (GDPR), and contractual obligations (SOC 2 Type II), into operational mandates. Adherence to this Framework is not optional; it is a condition of employment and a contractual requirement for all third-party processors.

1.2 SCOPE AND APPLICABILITY

This Framework applies globally to the "Cloud Shift Ecosystem," defined as:

- **Personnel:** All full-time employees, independent contractors, officers, and members of the Board of Directors.
- **Assets:** All Information Technology resources, including but not limited to cloud infrastructure (AWS/Azure), source code repositories, workstations, and proprietary algorithms (*VirtuHire*, *TaskFlow*, *Bison Finsight*).
- **Data:** All Client Data, Personal Information (PI), and Intellectual Property collected, generated, or processed by Cloud Shift.

1.3 REGULATORY HIERARCHY AND ALIGNMENT

Cloud Shift adopts a "Highest Common Denominator" approach to compliance. Where regulatory requirements conflict, Cloud Shift shall adhere to the strictest standard.

- Primary Jurisdiction: As a Canadian corporation, Cloud Shift is primarily governed by PIPEDA and Quebec Law 25.

- **Extraterritorial Compliance:**
    - **General Data Protection Regulation (GDPR):** Applied to all data subjects residing in the European Economic Area.
    - **California Consumer Privacy Act/California Privacy Rights Act (CCPA/CPRA):** Applied to data subjects residing in California.

- **Standards:** The organization aligns its controls with **SOC 2 Type II** (Trust Services Criteria) and **ISO/IEC 27001:2022** for information security management.

2.0 Governance Structure

2.1 Roles & Responsibilities

Accountability for security and privacy is formally delegated to the following roles. These designations define legal liability and decision-making authority.

Role	Designation	Fiduciary Responsibilities
Chief Executive Officer (CEO)	**The Data Trustee**	Ultimately accountable to the Board and Shareholders for the organization's risk posture. Sign off on "Residual Risk" and authorize the annual compliance budget.
Chief Information Security Officer (CISO)	**The Enforcer**	Responsible for the operational defense of the platform. Owns **Policy 04 (InfoSec)** and **Policy 06 (Incident Response)**. Holds authority to shut down production systems during a confirmed breach.
Privacy Officer (DPO)	**The Guardian**	Responsible for regulatory affairs, including **Policy 01 (Privacy)**. Serves as the primary point of contact for the Office of the Privacy Commissioner (OPC) and executes Data Subject Access Requests (DSAR).
VP of Engineering / CTO	**The Builder**	Responsible for **Policy 08 (SSDLC)**. Ensures that "Privacy by Design" and "Security by Default" principles are technically implemented in *VirtuHire*, *Bison Finsight*, and *TaskFlow*.

2.2 The Privacy & Security Committee

(a) **Mandate:** The PSC is the supreme decision-making body for data governance. It reviews the threat landscape, adjudicates on policy exceptions, and oversees the organization's response to critical risks.
(b) **Composition:** CEO (Chair), CISO, CTO, and Legal Counsel.
(c) **Meeting Cadence:** Quarterly (Q1, Q2, Q3, Q4) and ad-hoc during "Critical" incidents

2.3 Annual Review & Audit Cycle

(a) **Annual Framework Review:** This document must be reviewed and re-authorized by the PSC **Annually** or following any "Significant Change" (e.g., merger, acquisition, or new product launch).

(b) **Independent Audit:** Cloud Shift commits an annual third-party audit (SOC 2 Type II) to validate the operating effectiveness of the controls defined in **Part 3 (Procedures Registry)**.

2.4 Metrics and Control Monitoring

To validate the effectiveness of this Framework, the CISO shall report the following Key Performance Indicators (KPIs) to the Privacy & Security Committee on a quarterly basis:

(a) **Vulnerability Remediation:** Mean Time to Remediate (MTTR) for Critical vulnerabilities (Target: < 48 Hours).

(b) **User Awareness:** Percentage of employees who failed the most recent Phishing Simulation.

(c) **Access Governance:** Percentage of Access Reviews completed on time.

(d) **Vendor Risk:** Percentage of Tier 1 Vendors with valid, unexpired SOC 2 reports.

3.0 Data Classification Strategy

To ensure resource allocation matches risk, Cloud Shift adopts a strict data classification schema. All data created or processed by the organization must be classified into one of the following four tiers.

3.1 Data Classification Levels

Level	Classification	Definition	Examples	Mandatory Controls
L1	**Public**	Information intended for public release. Disclosure causes no harm.	• Marketing Website • Job Description • Public API Documentation	• Integrity Checks (Prevention of defacement)
L2	**Internal**	Business data intended for internal operations. Disclosure causes minor operational disruption.	• Internal Wikis (Confluence) • Org Charts • Slack Public Channels	• Access restricted to authenticated Employees. • Standard retention.
L3	**Confidential**	Sensitive proprietary or business data. Disclosure could cause financial loss, reputational damage, or loss of competitive advantage.	• **Bison Finsight** Ledgers • Source Code Repositories • **Practitioner 360** Partner Lists • Client Contracts	• **Encryption at Rest (AES-256)** • **MFA Required** for access • NDA required for Third Parties

L4	**Restricted**	Highly sensitive data triggering regulatory breach notification (RROSH) or contractual penalties.	• **VirtuHire** Candidate Videos • Biometric Data • Government "Protected B" Data • Production Database Credentials	• **Strict Need-to-Know** (Least Privilege) • **Data Sovereignty Enforced** • Access & Egress Logging • **WORM Storage** (Backups)

3.2 Data Sovereignty Principles (Canada vs. US vs. EU Residency)

To comply with the disparate regulatory requirements of our global client base, Cloud Shift enforces a "Sovereignty-by-Design" architecture. Data residency is determined by the **origin** of the data subject.

1. The "Canada First" Principle (Canadian Public Sector)

(a) **Mandate:** All data classified as **Restricted (L4)** that belongs to Canadian Public Sector clients or is "Protected B" must reside physically within Canada (Data At Rest).
(b) **Replication:** Disaster Recovery backups for this data must be replicated to a secondary *Canadian* region (e.g., ca-central-1 to ca-west-1) and **must not** cross into the United States.

2. The "PIPEDA Standard" Principle (Canadian Private Sector)

(a) **Mandate:** Data belonging to Canadian private sector clients may be stored in **Canada** or the **United States**, subject to the specific terms of the Client Data Processing Agreement (DPA).
(b) **Safeguards:** Cloud Shift ensures that any transfer to the US maintains a level of protection comparable to that required under PIPEDA.
(c) **Quebec Exception (Law 25):** For data originating from **Quebec**, Cloud Shift shall conduct a Privacy Impact Assessment (PIA) prior to transferring any Personal Information outside of the province to ensure legal equivalence.

3. The "GDPR Adequacy" Principle (European Union)

(a) **Mandate:** Personal Data originating from the European Economic Area (EEA) shall be stored within the EU (e.g., AWS Frankfurt/Dublin) or processed in **Canada**.
(b) **Legal Basis:** Canada is recognized by the European Commission as providing an "Adequate" level of data protection. Therefore, transfer from the EU to Canada is permitted without additional safeguards.

(c) **Restriction:** EU data **shall not** be transferred to or stored in the United States unless valid Standard Contractual Clauses (SCCs) are in place and a Transfer Impact Assessment (TIA) has been conducted.

4. The "Commercial Flexibility" Principle (United States)

(a) **Mandate:** Data belonging to US commercial clients may be stored in the United States (e.g., AWS us-east-1) or Canada, subject to the specific terms of the Client Master Services Agreement (MSA).

(b) **CCPA/CPRA:** Regardless of physical location, all data belonging to California residents must be tagged to ensure Cloud Shift can fulfill "Do Not Sell/Share" and "Limit Use of Sensitive Info" requests within 45 days.

5. Cross-Border Transfer Restriction (General)

(a) **Production Data:** No production dataset may be migrated from its designated "Home Region" (e.g., moving a database from Canada to the US) without the explicit, written consent of the Data Controller (Client) and approval from the Privacy Officer.

PART 2: THE POLICY MANUAL

The 11 mandatory policies that constitute the rules of the organization.

4.0 Domain A: Privacy & Legal Compliance

4.1 **Policy 01:** Data Privacy Policy (External & Internal)

Document ID: CLOUD SHIFT-POL-001
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Privacy Officer
Applicable Jurisdictions: Canada (Federal/Provincial), USA, EU/EEA

4.1.1 PURPOSE

The purpose of this policy is to define the principles and mandates governing the collection, use, disclosure, and management of Personal Information (PI) and Artificial Intelligence (AI) systems by Cloud Shift.

This policy ensures compliance with:

- **Canada:** *Personal Information Protection and Electronic Documents Act* (PIPEDA), *Quebec Law 25* (formerly Bill 64), and the *Artificial Intelligence and Data Act* (AIDA - Bill C-27 Framework).
- **Europe:** *General Data Protection Regulation* (GDPR).
- **USA:** *California Consumer Privacy Act* (CCPA/CPRA) and *Illinois Biometric Information Privacy Act* (BIPA).

4.1.2 SCOPE

This policy applies to:

1. **All Employees and Contractors** of Cloud Shift.
2. **All Cloud Shift Products:** Specifically *VirtuHire*, *Bison Finsight*, *Practitioner 360*, and *TaskFlow*.
3. **All Data Subjects:** Job candidates, client employees, and partners.

Exclusions: This policy does not apply to **irreversibly anonymized data** where the individual cannot be re-identified by any means reasonably likely to be used by Cloud Shift or a third party [Ref: PIPEDA S. 2(1); GDPR Recital 26]. Pseudonymized data (where a key exists) remains within scope.

4.1.3 POLICY STATEMENTS

4.1.3.1 Lawful Basis & Consent

Cloud Shift shall not collect Personal Information without a lawful basis [Ref: GDPR Art. 6; PIPEDA Principle 4.3].

(a) **For VirtuHire (Candidate Data):** Explicit, opt-in consent is required before any recording begins.
(b) **Biometric Information:** If Cloud Shift products analyze facial geometry or voiceprints (e.g., for identity verification or sentiment analysis), a **distinct, written release** must be obtained prior to collection, separate from the general Terms of Service.
(c) Consulting Dual-Role:
    a. *As Processor:* For client data processed during consulting engagements, Cloud Shift acts as a Data Processor governed by the Master Services Agreement (MSA).
    b. *As Controller:* For business contact information (e.g., client stakeholder emails) collected for relationship management, Cloud Shift acts as a Data Controller governed by this Policy.

4.1.3.2 Data Collection & Minimization

Cloud Shift adheres to "Data Minimization." We collect only data strictly necessary for the stated purpose [Ref: GDPR Art. 5(1)(c); PIPEDA Principle 4.4].

(a) **Prohibition on Scraping:** Cloud Shift tools shall not scrape data from public sources (e.g., LinkedIn) to enrich candidate profiles without explicit consent [Ref: OPC Guidelines on Scraping].

4.1.3.3 Data Residency & International Transfers

(a) **EU Data:** Personal data originating from the EU shall be stored within the EU or transferred only under Standard Contractual Clauses (SCCs) [Ref: GDPR Art. 46].
(b) **Canadian Public Sector:** Data classified as **Protected B** by Canadian government clients must remain resident in Canada and be accessible only by authorized personnel within Canada [Ref: ITSG-33; Treasury Board Directive on Service and Digital].

4.1.3.4 Automated Decision Making & AI Transparency

Recognizing Cloud Shift's use of AI (e.g., VirtuHire scoring, TaskFlow automation):

(a) **Transparency:** Users must be informed if an AI system is used to make a prediction, recommendation, or decision about them [Ref: AIDA S. 8; Quebec Law 25 S. 12.1].
(b) **Right to Human Review:** Users retain the right to request human intervention for any decision made solely by automated means that produces legal or similarly significant effects (e.g., rejection of a job application) [Ref: GDPR Art. 22; Bill C-27].

(c) **Bias Monitoring:** All High-Impact AI systems must undergo testing for bias and performance monitoring before deployment [Ref: AIDA S. 9].

4.1.3.5 Data Retention & Destruction

Personal Information shall not be retained indefinitely [Ref: PIPEDA Principle 4.5].

(a) **Retention Schedule:** Candidate video data in VirtuHire must be deleted or irreversibly anonymized after **6 months** unless the candidate consents to a "Talent Pool" retention period.
(b) **Destruction:** Data must be destroyed using secure methods (e.g., cryptographic erasure) that render it unrecoverable.

4.1.3.6 Third-Party Sharing

Cloud Shift shall not sell Personal Information to third parties [Ref: CCPA S. 1798.120].

(a) **Partners:** Data shared via *Practitioner 360* must be governed by a written agreement ensuring the partner provides a comparable level of protection [Ref: PIPEDA Principle 4.1.3].

4.1.3.7 Marketing & Anti-Spam Compliance (CASL)

Cloud Shift complies with Canada's Anti-Spam Legislation (CASL).

(a) **Consent:** "Express Consent" (opt-in) is required for all Commercial Electronic Messages (CEMs). Implied consent (existing business relationship) must be tracked and expires after 2 years.

(b) **Unsubscribe Mechanism:** All CEMs must include a functional unsubscribe link. Unsubscribe requests must be processed automatically within **10 business days**.

(c) **Identification:** All marketing messages must clearly identify Cloud Shift as the sender and provide valid contact information.

4.1.4 DATA SUBJECT RIGHTS

Cloud Shift provides mechanisms (via the Privacy Portal) for individuals to exercise their rights:

(a) **Right to Access:** Request a copy of their data [Ref: PIPEDA Principle 4.9; GDPR Art. 15].
(b) **Right to Erasure:** Request deletion of data [Ref: GDPR Art. 17].
(c) **Right to Portability:** Receive data in a structured, commonly used format [Ref: Quebec Law 25 S. 27; GDPR Art. 20].

4.1.5 ENFORCEMENT

Violations of this policy may result in disciplinary action, up to and including termination of employment and legal action. The Privacy Officer is responsible for monitoring compliance.

4.2 **Policy 02:** Data Retention & Destruction Policy

Document ID: CLOUD SHIFT-POL-002
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Chief Information Security Officer (CISO) / Legal Counsel
Reference Standards: PIPEDA, GDPR Art. 17, CRA (Income Tax Act), NIST 800-88

4.2.1 PURPOSE

This policy establishes the official retention periods for data assets managed by Cloud Shift. It ensures that data is kept only as long as necessary for business or legal purposes and is securely destroyed thereafter, complying with the principle of "Storage Limitation" under GDPR and PIPEDA.

4.2.2 SCOPE

This policy applies to all electronic and physical data generated or processed by Cloud Shift, specifically covering:

1. **Product Data:** *VirtuHire* (Candidate videos), *TaskFlow* logs.
2. **Corporate Data:** *Bison Finsight* (Internal financials), *Practitioner 360* (Partner records).
3. **Client Data:** Information processed during consulting engagements.

4.2.3 RETENTION SCHEDULE

The following table dictates the mandatory retention periods. "Active" refers to the duration of the contract, employment, or user account validity.

Data Category	Data Type	Retention Period	Rationale / Legal Basis
VirtuHire (Candidates)	Video/Audio Recordings (Rejected Candidates)	**6 Months** after rejection	Limitation period for discrimination claims; GDPR Data Minimization.
VirtuHire (Candidates)	Video/Audio Recordings (Hired Candidates)	**Transferred to HR File and verify**	Becomes part of the Employment Record (see below).
VirtuHire (Candidates)	Anonymized Aggregated Data	**Indefinite**	Used for AI model training (must be irreversibly anonymized).
Consulting Services	Client Data (Project Files, Code, Datasets)	**Contract End + 90 Days**	Allowance for warranty period/handover, then destroy.

Corporate Finance	*Bison Finsight* Data, Tax Records, Invoices	**Current Year + 6 Years**	Canadian Income Tax Act (CRA) requirements; FINTRAC Guidelines.
HR & Employment	Employee Records (Contracts, Payroll)	**Employment End + 7 Years**	Limitation periods for wrongful dismissal/tax audits.
Security Logs	System Access Logs, Firewall Logs	**1 Year**	Forensic availability for breach investigation.
Backups	Database Snapshots, DR Backups	**90 Days (Rolling)**	Disaster Recovery standard cycle.

4.2.4 DESTRUCTION & DISPOSAL

Data must be disposed of using methods that prevent reconstruction. Simple "deletion" is insufficient for sensitive data.

4.2.4.1 Electronic Data

(a) **Standard Deletion:** For general files, standard OS deletion is sufficient.
(b) **Sensitive Data (PII/PHI/Credentials):** Must be securely purged using **Cryptographic Erasure** (deleting the encryption key) or overwriting software (following NIST 800-88 Guidelines).
(c) **Physical Media:** Hard drives or servers decommissioned from the data center must be physically destroyed (shredded/degaussed).

4.2.4.2 Backup Data ("Put Beyond Use")

Cloud Shift acknowledges that immediate deletion of individual records from immutable backups is technically impractical.

(a) **Protocol:** If a deletion request (e.g., GDPR Right to Erasure) is received, the “live data” is deleted immediately. The data remaining in backups is placed "Beyond Use"—meaning it must not be restored to a live system. If a full system restore occurs, the specific record must be re-deleted immediately.

4.2.5 EXCEPTIONS & LITIGATION HOLD

CRITICAL: If Cloud Shift is involved in (or reasonably anticipates) a lawsuit, regulatory investigation, or audit:

1. A **Litigation Hold** notice will be issued by Legal Counsel.
2. **ALL AUTOMATED DELETION MUST STOP** for relevant data.
3. Destroying data under a Litigation Hold is a criminal offense (Spoliation of Evidence).

4.2.6 ENFORCEMENT

Automated scripts shall be configured to execute this schedule. Manual periodic audits will verify compliance.

4.3 **Policy 03:** Third-Party & Vendor Risk Management Policy

Document ID: CLOUD SHIFT-POL-003
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Chief Information Security Officer (CISO)
Reference Standards: SOC 2 (Vendor Management), ISO 27001:2022 (A.5.19), PCI-DSS (Requirement 12.8)

4.3.1 PURPOSE

The purpose of this policy is to define the framework for identifying, assessing, and mitigating risks associated with third-party vendors, service providers, and partners. This policy ensures that any external entity with access to Cloud Shift's systems or data adheres to security standards equivalent to or stricter than our own, complying with the *Personal Information Protection and Electronic Documents Act* (PIPEDA) [Principle 4.1.3] and the *General Data Protection Regulation* (GDPR) [Article 28].

4.3.2 SCOPE

This policy applies to all external parties ("Vendors") that process data or provide infrastructure for Cloud Shift, categorized as follows:

1. **Critical Infrastructure Providers:** Entities hosting our core platform (e.g., Cloud Service Providers like Amazon Web Services (AWS) or Microsoft Azure).
2. **Sub-Processors:** Third parties that process data on our behalf (e.g., Payment Processors, Email Delivery Services).
3. **Business Partners:** External users of the *Practitioner 360* tool.
4. **Contingent Workforce:** Independent contractors, freelancers, and consultants hired for specific projects.

4.3.3 VENDOR CLASSIFICATION & RISK ASSESSMENT

Not all vendors pose the same risk. The CISO shall classify vendors into tiers to determine the depth of due diligence required.

(a) **Tier 1 (Critical Risk):** Vendors who host, process, or have logical access to "Confidential" or "Restricted" data (including Client Data and Personal Information). Failure of this vendor would disrupt Cloud Shift's business operations.
    a. *Requirement:* Full Security Audit, SOC 2 Type II Review, Data Processing Agreement (DPA).
(b) **Tier 2 (Operational Risk):** Vendors with access to internal business data but no access to Client Data or Production Environments (e.g., Marketing software).
    a. *Requirement:* Standard Security Questionnaire, Non-Disclosure Agreement (NDA).
(c) **Tier 3 (Low Risk):** Vendors with no access to data or systems (e.g., Office cleaning services).
    a. *Requirement:* Basic contract only.

4.3.4 POLICY STATEMENTS

4.3.4.1 The "Fortress Model" (Data Residency & Egress)

Cloud Shift operates under a strict "Data Residency" model.

(a) **Prohibition on Egress:** Personal Information (PI) and Client Data shall **NOT** be transferred, copied, or exported to third-party environments unless strictly required for the function (e.g., backups to Azure) and authorized by the CISO.
(b) **Partner Access:** Partners using *Practitioner 360* must access data **solely within** Cloud Shift's secure cloud environment. They are granted "Least Privilege" access (view-only or limited processing) and are technically restricted from bulk data extraction.

4.3.4.2 Vendor Selection & Due Diligence

Before engaging a Tier 1 Vendor, Cloud Shift must validate their security posture.

(a) **Certification Review:** Critical vendors must possess a valid **System and Organization Controls (SOC) 2 Type II** report or **ISO/IEC 27001** certification. If a critical vendor lacks these certifications, the CISO may authorize their use only after conducting a manual Security Audit and signing a formal 'Risk Acceptance Form'.
(b) **PCI Compliance:** Any vendor involved in payment flows must be validated as **Payment Card Industry Data Security Standard (PCI-DSS)** Level 1 compliant.
(c) **Background Checks:** For independent contractors, Cloud Shift reserves the right to conduct criminal background checks, commensurate with local laws and client requirements (especially for Government "Protected B" contracts).

4.3.4.3 Contractual Obligations

Contracts with Tier 1 and Tier 2 vendors must include:

(a) **Right to Audit:** A clause granting Cloud Shift the right to review the vendor's security compliance annually.

(b) **Data Processing Agreement (DPA):** A binding agreement defining how data is handled, compliant with GDPR [Art. 28] and PIPEDA.
(c) **Notification of Breach:** A strict requirement for the vendor to notify Cloud Shift of any security incident within **24 to 48 hours** of discovery.
(d) **Data Sovereignty Clause:** For vendors handling Canadian Government data, a guarantee that data will not be routed through or stored in foreign jurisdictions without express written consent.

4.3.4.4 Payment Processing (Financial Isolation)

To minimize financial fraud risk:

(a) **No Storage of PAN:** Cloud Shift systems (*Bison Finsight*, *TaskFlow*) shall **NEVER** store, process, or transmit full Primary Account Numbers (PAN) or Card Verification Values (CVV).
(b) **Methodology:** All payment acceptance must use "Hosted Payment Pages" or Tokenization methods provided by the PCI-DSS validated processor.

4.3.4.5 Contractor & Freelancer Governance

Independent workers are treated as high-risk "Insiders."

(a) **Non-Disclosure Agreement (NDA):** Must be signed prior to *any* system access.
(b) **Device Control:** Contractors working on "Protected B" data must use Cloud Shift-managed devices or Virtual Desktop Infrastructure (VDI). Use of personal, unmanaged devices for government data is strictly prohibited.
(c) **Access Termination:** Contractor access is provisioned with a hard "Expiration Date" matching their contract end date.

4.3.5 ONGOING MONITORING & OFFBOARDING

4.3.5.1 Continuous Monitoring

The CISO is responsible for an **Annual Vendor Review** for all Tier 1 vendors to ensure their security certifications (e.g., SOC 2, PCI-DSS) have not expired.

4.3.5.2 Offboarding & Termination

Upon termination of a vendor relationship:

(a) **Immediate Access Revocation:** All API keys, user accounts, and VPN access must be revoked within **one (1) business day** of contract termination, or **immediately** in the event of termination for cause or security breach.
(b) **Data Destruction:** The vendor must provide a "Certificate of Destruction" or written confirmation that all Cloud Shift data has been securely deleted from their systems within **30 days** of contract termination.

4.3.6 ENFORCEMENT

Entering a contract with a software vendor or sharing Cloud Shift data without following this Due Diligence process is a violation of this policy and may result in disciplinary action.

5.0 Domain B: Information Security (InfoSec)

5.1 **Policy 04:** Information Security Policy (Master Policy)

Document ID: CLOUD SHIFT-POL-004
Version: 1.0 **Effective Date:** March 03, 2026
Policy Owner: Chief Information Security Officer (CISO)
Reference Standards: NIST SP 800-53 (SC-7, SI-4), SOC 2 (CC6.1, CC6.6), ISO 27001:2022 (A.8.20)

5.1.1 PURPOSE

The purpose of this policy is to define the technical and administrative controls required to protect the confidentiality, integrity, and availability of Cloud Shift's information assets. It establishes the mandatory security baseline for *VirtuHire*, *Bison Finsight*, *Practitioner 360*, and our corporate infrastructure.

5.1.2 SCOPE

This policy applies to:

(a) **Infrastructure:** All cloud environments (AWS/Azure), servers, networks, and databases.
(b) **Endpoints:** All workstations, laptops, and mobile devices used to access Cloud Shift data (Company-owned or BYOD).
(c) **Personnel:** All employees, contractors, and third-party users.

5.1.3 NETWORK SECURITY & SEGMENTATION

To prevent lateral movement by attackers, Cloud Shift's network must be segmented.

5.1.3.1 Network Segmentation

(a) **Production Isolation:** Production environments (hosting Client Data) must be logically isolated from Non-Production environments (Development, Staging, QA).
(b) **Database Isolation:** Databases containing Personal Information (PI) or Financial Data (*Bison Finsight*) must reside in private subnets with no direct inbound access from the public internet. Access is permitted only via a Bastion Host or Virtual Private Network (VPN).

(c) **Micro-Segmentation:** Services should be segmented based on function. For example, the *VirtuHire* video processing service should not have network access to the *Bison* financial database.

5.1.3.2 Perimeter Defense

(a) **Firewalls:** All network boundaries must be secured by Next-Generation Firewalls (NGFW) or Cloud Security Groups. "Allow All" (0.0.0.0/0) rules are strictly prohibited on internal ports (e.g., SSH port 22, RDP port 3389).
(b) **Web Application Firewall (WAF):** All public-facing web applications (*VirtuHire*, *TaskFlow*) must be protected by a WAF to filter malicious traffic (e.g., SQL Injection, Cross-Site Scripting).
(c) **DDoS Protection:** Critical services must implement Distributed Denial of Service (DDoS) mitigation (e.g., AWS Shield).

5.1.4 ASSET SECURITY & BYOD GOVERNANCE

5.1.4.1 Asset Inventory & Hardening

(a) **Inventory:** The IT Team must maintain an automated, up-to-date inventory of all authorized software and cloud assets.
(b) **Secure Configuration:** All systems must be provisioned using hardened configuration standards (e.g., Center for Internet Security (CIS) Benchmarks). Default vendor passwords must be changed immediately upon provisioning.

5.1.4.2 Workstation Security (BYOD Baseline)

Since Cloud Shift operates a Bring Your Own Device (BYOD) model, all personal devices used for work must meet the following "Health Check" standards:

(a) **Disk Encryption:** Full Disk Encryption (FileVault for Mac, BitLocker for Windows) is mandatory.
(b) **Antivirus/EDR:** An approved Endpoint Detection & Response (EDR) agent must be active.
(c) **Screen Lock:** Devices must be configured to lock the screen automatically after a maximum of **15 minutes** of inactivity.

5.1.4.3 The "Secure Enclave" (Data Leakage Prevention)

To comply with Government "Protected B" requirements on BYOD assets:

(a) **Prohibition:** Employees shall **NEVER** download Client Data, PII, or Source Code directly to the local hard drive of a personal device.
(b) **VDI Requirement:** Access to sensitive production environments must occur via a **Virtual Desktop Infrastructure (VDI)** (e.g., AWS WorkSpaces) or a secure browser session or

Company-Managed Device with verified Endpoint Detection & Response (EDR) and strict Data Loss Prevention (DLP) controls enabled.

5.1.5 CRYPTOGRAPHY & ENCRYPTION

Cloud Shift mandates strong encryption to protect data throughout its lifecycle.

5.1.5.1 Data in Transit

(a) **Standard: Transport Layer Security (TLS) protocol 1.3** is the mandatory minimum for all external web traffic (HTTPS).
(b) **Internal Traffic:** Service-to-service communication within the cloud environment must also be encrypted.

5.1.5.2 Data at Rest

(a) **Standard: Advanced Encryption Standard with a 256-bit key** is the mandatory encryption standard for all data at rest.
(b) **Scope:** This applies to Databases, Object Storage (Azure Blob storage), Virtual Machine (VM) disks, and Backups.
(c) **Key Management:** Encryption keys must be managed via a centralized Key Management Service (KMS) and rotated annually. Keys must never be hardcoded in source code repositories.

5.1.6 VULNERABILITY MANAGEMENT

Cloud Shift adopts a proactive stance towards discovering and fixing security flaws.

5.1.6.1 Scanning & Penetration Testing

(a) **Automated Scanning:** Vulnerability scans must run **weekly** on all production infrastructure.
(b) **Penetration Testing:** Third-party penetration tests must be conducted **annually** or after any significant application release.

5.1.6.2 Patch Management

Security patches must be applied based on risk severity:

(a) **Critical (Common Vulnerability Scoring System (CVSS) 9.0+):** Critical patches must be applied within 48 hours, **or if patching is not immediately feasible, mitigating controls (e.g., isolating the system) must be applied within that timeframe.**
(b) **High (CVSS 7.0-8.9):** Patch within **14 days**.
(c) **Medium/Low:** Patch within **30 days** or next maintenance window.

5.1.7 LOGGING & MONITORING

To ensure timely detection of incidents.

5.1.7.1 Centralized Logging

(a) **Requirement:** All systems (Firewalls, Servers, Authentication Providers) must send logs to a centralized Security Information and Event Management (SIEM) system or aggregated log repository.
(b) **Immutable Logs:** Logs must be protected from tampering (e.g., "Write Once, Read Many" storage) to preserve forensic integrity.

5.1.7.2 Alerting

(a) **Triggers:** Alerts must be configured for suspicious activities, including:
    a. Multiple failed login attempts (Brute Force).
    b. Privilege escalation events.
    c. Traffic to known malicious IP addresses.

5.1.8 PHYSICAL SECURITY

Even in a remote-first or hybrid environment, physical security is required.

(a) **Clean Desk Policy:** Employees working with sensitive paper documents or hardware keys must secure them in a locked drawer when unattended.
(b) **Visitor Control:** Any physical office locations must control visitor access via a logbook and escort policy.

5.1.9 ENFORCEMENT

Any attempt to bypass security controls (e.g., disabling antivirus, bridging networks, modifying logs) is a violation of this policy and subject to disciplinary action.

5.2 **Policy 05:** Access Control & Identity Management Policy

Document ID: CLOUD SHIFT-POL-005
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: IT Director / CISO
Reference Standards: NIST SP 800-63B, SOC 2 (CC6.1, CC6.2, CC6.3), ISO 27001:2022 (A.5.15, A.9.4)

5.2.1 PURPOSE

The purpose of this policy is to ensure that access to Cloud Shift's information systems is restricted to authorized users and that legitimate users have access only to the data necessary for their role.

This policy enforces the principles of "Least Privilege," "Segregation of Duties," and "Need-to-Know."

5.2.2 SCOPE

This policy applies to:

1. **Internal Identities:** All employees, contractors, and administrators.
2. **External Identities:** Clients, Partners (*Practitioner 360*), and Candidates (*VirtuHire*).
3. **Machine Identities:** Service accounts, API keys, and bots used for automation (*TaskFlow*, *Bison*).
4. **Systems:** All applications, databases, cloud infrastructure (AWS/Azure), and VPNs owned by Cloud Shift.

5.2.3 AUTHENTICATION STANDARDS

5.2.3.1 Unique Identification

(a) **One Person, One ID:** Every human user must have a unique User ID. Shared accounts (e.g., "firstname.lastname@Cloud Shift.ne" shared by 3 devs) are **strictly prohibited** for human use.
(b) **SSO Mandate:** Where technically feasible, all internal applications (e.g., Slack, GitHub, Jira, Azure) must be integrated with a centralized Identity Provider (IdP) (e.g., Google Workspace, Okta) using Single Sign-On (SSO).

5.2.3.2 Password Policy (Internal Users)

Cloud Shift aligns with modern **National Institute of Standards and Technology Special Publication 800-63B (NIST SP 800-63B)** guidelines to balance security and usability.

(a) **Complexity:** Minimum length of **12 characters**. Passphrases (e.g., "Correct-Horse-Battery-Staple") are encouraged.
(b) **Rotation:** Passwords shall **NOT** expire periodically (e.g., no 90-day forced rotation). Forced rotation is required **only** if a compromise is suspected or detected.
(c) **Breach Screening:** Passwords must be checked against known breach lists (e.g., HaveIBeenPwned) upon creation.
(d) **Anti-DoS Lockout:** To prevent "Denial of Service" attacks against valid users, the system shall enforce **Rate Limiting** (exponential backoff) or **CAPTCHA** challenges after 10 failed attempts, rather than a hard permanent lockout.

5.2.3.3 Multi-Factor Authentication (MFA)

(a) **Internal Mandate:** MFA is **MANDATORY** for all Employee and Contractor accounts.
    a. *Preferred Factors:* WebAuthn (TouchID/FaceID), Hardware Keys (YubiKey), or Authenticator Apps (**Time-Based One-Time Password** (TOTP)).
    b. *Restricted Factors:* SMS/Voice codes are discouraged due to SIM-swapping risks.

(b) **Partner Mandate:** MFA is **MANDATORY** for Business Partners accessing *Practitioner 360*.
(c) **Candidate Exception:** MFA is **Optional** for *VirtuHire* Candidates to minimize friction during the interview process.

5.2.4 THE USER ACCESS LIFECYCLE

5.2.4.1 Onboarding & Role-Based Access

(a) **"Birthright" Access:** New employees are granted a standard set of permissions based on their role on Day 1.
(b) **Role-Based Access Control (RBAC):** Access is granted based on the user's "Role" (e.g., "Junior Python Dev"), not their individual request.

5.2.4.2 Movers (Transfers)

(a) **The "Clean Slate" Rule:** When an employee changes roles, their previous access rights must be **reviewed and revoked** before new rights are granted. Permissions must not "stack" indefinitely.

5.2.4.3 Offboarding (Terminations)

Upon termination of employment or contract:

(a) **Standard Termination:** Access to all systems must be revoked within **24 hours** (One Business Day) of the effective termination date.
(b) **Hostile Termination:** If an employee is terminated for cause, access must be revoked **simultaneously with** the commencement of the termination meeting, to prevent premature alerting or data exfiltration.
(c) **Session Kill:** All active sessions (SSO tokens, VPN connections) must be forcibly terminated.

5.2.5 PRIVILEGED ACCESS MANAGEMENT (PAM)

5.2.5.1 Administrative Accounts

(a) **Separation of Duties:** Where feasible, Administrators should have a separate "Admin Account" for privileged tasks.
(b) **Cost Exception:** If licensing costs or technical constraints make dual accounts prohibitive, Administrators may use a single account provided that **Just-in-Time (JIT) elevation** or strict MFA is enforced for sensitive tasks.
(c) **No Daily Use:** "Root" or "Superuser" privileges must not be used for daily activities like reading email.

5.2.5.2 "Break-Glass" Procedures

(a) **Emergency Access:** For critical infrastructure (e.g., AWS Root Account), credentials must be vaulted and protected.
(b) **Logging:** Any use of a "Break-Glass" account must trigger an immediate high-priority alert to the security team.

5.2.6 SERVICE ACCOUNTS & MACHINE IDENTITIES

(a) **Non-Interactive:** Service accounts must be configured to deny interactive login (e.g., no shell access) wherever possible.
(b) Key Rotation: API Keys and Service Account credentials must be rotated at least **Annually**, **OR immediately** upon the departure of any staff member with knowledge of that key**.**
(c) **Storage:** Secrets (API Keys, Database Passwords) must **NEVER** be hardcoded in source code (Git). They must be injected via a Secrets Manager.

5.2.7 ACCESS REVIEW

To ensure permissions do not accumulate over time ("Privilege Creep"):

(a) **Frequency:** Access rights for all employees and contractors must be reviewed **Semi-Annually (Every 6 Months)**.
(b) **Process:** System Owners review the list of users and revoke access for anyone who has changed roles or no longer requires it.
(c) **Sign-Off:** The review must be formally documented and signed off by the CISO.

5.2.8 SESSION MANAGEMENT

(a) **Idle Timeout:** Sessions for sensitive applications (e.g. AWS Console) must automatically terminate after **15 to 30 minutes** of inactivity.
(b) **Re-Authentication:** Users must re-authenticate at least once every **12 to 24 hours**.

5.2.9 ENFORCEMENTS

Sharing passwords, MFA tokens, or SSH keys with colleagues is a strict violation of this policy.

5.3 **Policy 06:** Incident Response & Breach Notification Policy

Document ID: CLOUD SHIFT-POL-006
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Chief Information Security Officer (CISO)
Reference Standards: NIST SP 800-61 r2; PIPEDA (Breach of Security Safeguards Regulations); GDPR (Arts. 33-34)

5.3.1 PURPOSE

The purpose of this Policy is to establish a structured, legally compliant framework for the management of security incidents at Cloud Shift. This Policy ensures that the organization can detect, analyze, contain, and recover from security breaches while adhering to the mandatory notification timelines required by Canadian (PIPEDA), European (GDPR), and other applicable privacy laws.

5.3.2 SCOPE AND DEFINITIONS

5.3.2.1 Scope

This Policy applies to all employees, contractors, and third-party vendors accessing Cloud Shift's information assets, including but not limited to *VirtuHire*, *Bison Finsight*, *Practitioner 360*, and corporate infrastructure.

5.3.2.2 Definitions

To prevent "alert fatigue" and ensure appropriate resource allocation, Cloud Shift distinguishes between the following:

(a) Security Event: An observable occurrence in a system or network (e.g., a blocked firewall port, a failed login attempt, or a system warning). Security Events are logged for review but do not automatically trigger the Incident Response Protocol defined in this Policy.

(b) Security Incident: A confirmed Security Event that violates Cloud Shift's security policies or jeopardizes the confidentiality, integrity, or availability of data (e.g., confirmed malware infection, unauthorized data exfiltration, active ransomware, or successful privilege escalation). This Policy applies strictly to Security Incidents.

5.3.3 INCIDENT RESPONSE GOVERNANCE

5.3.3.1 The Incident Response Team (IRT)

The IRT is responsible for the execution of this Policy. Key roles include:

(a) Incident Commander: The Chief Information Security Officer (CISO) holds the ultimate authority to declare a Security Incident, authorize system shutdowns, and direct recovery efforts.

(b) Legal Counsel: Responsible for regulatory interpretation, preserving legal privilege, and overseeing external notifications.

(c) Technical Leads: DevOps and Engineering Leads responsible for forensic containment and system restoration.

5.3.3.2 Confidentiality and Communications Embargo

Strict confidentiality is required during an active Security Incident to prevent reputational damage and legal liability.

(a) Embargo: Only the Incident Commander or Legal Counsel is authorized to communicate with external parties, including the press, social media, or clients, regarding an active incident.

(b) Prohibition: Employees are strictly prohibited from discussing active incidents, rumors, or speculation on personal social media channels or public forums. Violation of this embargo may result in immediate disciplinary action.

5.3.4 INCIDENT RESPONSE LIFECYCLE

Cloud Shift adheres to the National Institute of Standards and Technology **(NIST) SP 800-61** four-phase lifecycle for incident management.

5.3.4.1 Phase 1: Preparation

The IT Team shall ensure that monitoring tools are active and logging to a centralized, immutable repository. The IRT shall conduct a "Tabletop Exercise" (simulation) at least annually to validate the effectiveness of this Policy.

5.3.4.2 Phase 2: Detection and Analysis

(a) Reporting Requirement: Any employee who suspects a Security Incident must report it to the Security Team (security@Cloud Shift.net) immediately, and in no event later than one (1) hour after discovery.

(b) Triage: The Incident Commander shall classify the incident severity (Critical, High, Medium, or Low) to determine the appropriate response level.

5.3.4.3 Phase 3: Containment, Eradication, and Recovery

(a) Containment: The IRT shall take immediate steps to limit the scope of the incident (e.g., revoking compromised API keys, isolating infected endpoints).

(b) Preservation of Evidence (Critical): Prior to any eradication or restoration efforts, a forensic image (snapshot) of the compromised system must be preserved. The IT Team shall not delete logs, re-image servers, or shut down volatile memory until evidence has been secured for insurance and legal purposes.

(c) Eradication and Recovery: Once evidence is preserved, the IRT shall remove the root cause (e.g., patching vulnerabilities) and restore systems from known clean backups.

5.3.4.4 Phase 4: Post-Incident Activity

For all incidents classified as "High" or "Critical," the IRT must conduct a Post-Mortem review within fourteen (14) days of incident closure. The findings shall be documented in a "Lessons Learned" report to prevent recurrence.

5.3.5 BREACH NOTIFICATION OBLIGATIONS

5.3.5.1 Client Notification (Data Controllers)

(a) Trigger: In the event of a confirmed Data Breach affecting Client Data, Cloud Shift shall notify the affected Client (Data Controller) without undue delay, and typically within **forty-eight (48) to seventy-two (72) hours** following confirmation of the breach.

(b) Prohibition on Speculation: To prevent unnecessary alarm and potential liability, notification shall not be issued based on mere suspicion or unverified anomalies. Notification requires positive confirmation of a compromise by the Incident Commander.

5.3.5.2 Regulatory Notification

(a) Canada (PIPEDA): Cloud Shift shall notify the Office of the Privacy Commissioner of Canada (OPC) if the breach creates a "Real Risk of Significant Harm" (RROSH) to affected individuals. The determination of RROSH is a legal conclusion and must be made **jointly by the CISO and Legal Counsel**.

(b) Europe (GDPR): If applicable, Cloud Shift shall notify the relevant Supervisory Authority within **seventy-two (72) hours** of becoming aware of the breach, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

5.3.5.3 Individual Notification

Where a breach poses a high risk to the rights and freedoms of individuals (e.g., risk of identity theft or financial loss), Cloud Shift shall notify the affected individuals directly, providing clear instructions on steps they can take to protect themselves.

5.3.6 ENFORCEMENT

Failure to report a suspected Security Incident is a violation of this Policy. Any employee who knowingly conceals a breach or violates the Communications Embargo may be subject to disciplinary action, up to and including termination of employment.

5.4 **Policy 07:** Remote Access & Work-From-Home (WFH) Policy

Document ID: CLOUD SHIFT-POL-007
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Chief Information Security Officer (CISO)
Reference Standards: NIST SP 800-46 Rev 2; ISO 27001:2022 (A.6.7); SOC 2 (CC6.1, CC6.7)

5.4.1 PURPOSE

The purpose of this Policy is to define the standards for connecting to Cloud Shift's internal network and accessing organizational assets from outside the corporate office. As Cloud Shift operates under a "Remote-First" model using Bring Your Own Device (BYOD) assets, this Policy is critical to maintaining the confidentiality, integrity, and availability of Client Data (*VirtuHire*, *Bison Finsight*) and Intellectual Property while employees work from remote locations.

5.4.2 SCOPE

This Policy applies to all employees, contractors, vendors, and agents with Cloud Shift owned or personally owned computers or workstations used to connect to the Cloud Shift network. This Policy applies to remote work performed in any location other than Cloud Shift's primary corporate offices, including home offices, shared workspaces, and public venues.

5.4.3 REMOTE WORK ENVIRONMENT STANDARDS

5.4.3.1 Physical Security and "Clean Desk"

(a) Workspace Security: Employees working remotely must ensure that their workspace is secure. Sensitive documents, notes, or hardware tokens (e.g., YubiKeys) must not be left unattended or visible to unauthorized people.

(b) Visual Privacy: When accessing Client Data (specifically *VirtuHire* candidate videos), employees must ensure that their screen is not visible to others.

(c) Public Venues: When working from public locations (e.g., cafes, airports, transit), employees must adhere to the following strict security protocols:

(a) **Network Hygiene**: The use of unsecured public Wi-Fi is strictly prohibited unless a corporate VPN is active to encrypt all traffic.
(b) **Physical Security**: Devices must never be left unattended. Employees must use personal power adapters and avoid public USB charging stations to prevent malware injection ("Juice Jacking").
(c) **Enhanced Locking**: Unlike the standard 15-minute window, devices used in public spaces must be manually locked immediately when not in use or configured for a shortened auto-lock timeout (e.g., 5 minutes).

5.4.3.2 Family and Guest Access

(a) Total Prohibition: Family members, household members, and guests are strictly prohibited from using Cloud Shift-owned devices regardless of whether a secure session is active.

(b) Voice Assistants: Employees **must** mute or disable smart speakers (e.g., Alexa, Google Home, Siri) in the workspace during confidential meetings to prevent the inadvertent recording or transmission of sensitive business discussions.

5.4.3.3 Printing and Paper Records

(a) General Prohibition: The printing of Client Data, Personal Information (PI), or internal confidential documents at remote locations is **strictly prohibited**.

(b) Exception: If printing is strictly required for a specific legal or business function, the employee must possess a cross-cut shredder and must securely destroy the physical documents immediately after use. Disposal of intact documents in household trash or recycling is a violation of this Policy.

5.4.4 SECURE CONNECTIVITY

5.4.4.1 Connection Methods and Zero Trust

(a) **Zero Trust Network Access (ZTNA)**: Cloud Shift operates on a "never trust, always verify" model. Perimeter defenses are insufficient; therefore, users and their respective devices must be continuously authenticated and authorized for every session before accessing corporate applications.

(b) Mandatory VPN Use: For accessing internal company resources, legacy infrastructure, or databases not natively protected by the ZTNA gateway, employees must use the corporate Virtual Private Network (VPN) to establish a secure, encrypted tunnel.

5.4.4.2 Public Wi-Fi Usage

(a) Strict Prohibition: Accessing Cloud Shift systems over unsecured or open public Wi-Fi networks (e.g., cafes, airports, hotels) is strictly prohibited.

(b) VPN Mandate: If an employee must use a public Wi-Fi network, the corporate VPN must be activated immediately upon connection to encrypt all internet traffic before any company data is accessed or transmitted.

5.4.4.3 Home Network Security Standards

(a) Router Hardening: Employees working from home are required to secure their personal Wi-Fi routers. This includes changing default administrator passwords, enabling WPA2 or WPA3 encryption, and ensuring router firmware is kept up to date.

(b) Network Segmentation: To prevent lateral movement from compromised personal devices, employees are strongly encouraged to segment their home networks (e.g., using a "Guest Wi-Fi"

feature) to logically separate Cloud Shift work devices from personal Internet of Things (IoT) devices, such as smart TVs and voice assistants.

5.4.5 ENDPOINT SECURITY (BYOD CONTEXT)

In accordance with Policy 04 (Information Security), all remote devices must maintain a robust security posture to prevent the introduction of malware into the corporate network.

5.4.5.1 Device Health Checks (Endpoint Controls) Prior to granting remote access or establishing a ZTNA/VPN session, the specific device must demonstrate compliance with the following mandatory health checks:

(a) **End-to-End Encryption:** Full-disk encryption (e.g., BitLocker for Windows, FileVault for macOS) must be active on all laptops and mobile devices to protect data at rest in the event of device theft or loss.

(b) **Endpoint Detection and Response (EDR):** An approved EDR agent must be actively deployed and running. The EDR tool must be configured to monitor for malicious activity, enabling real-time threat detection and the capability for the Security Team to execute remote isolation of compromised devices.

(c) **Patch Management:** The device must be configured for automatic updates. Timely patching of operating systems, web browsers, applications, and security software is mandated to protect against known vulnerabilities.

5.4.5.2 Data Residency and Local Storage

(a) **Prohibition on Local Storage:** To comply with Government "Protected B" and Client Data requirements, employees shall not download, store, or retain Client Data, Personal Information (PI), or Source Code on the local hard drive of a remote device.

(b) **VDI Requirement:** Access to sensitive production data must be performed via a Virtual Desktop Infrastructure (VDI) or secure browser session where data remains resident in the cloud environment.

5.4.6 INCIDENT REPORTING

Remote employees are the first line of defense. In the event of a lost or stolen device, or if a device is suspected to be compromised (e.g., unusual pop-ups, ransomware note), the employee must:

(a) Disconnect: Immediately disconnect the device from the corporate network (VPN/Wi-Fi).

(b) Report: Notify the Security Team (security@Cloud Shift.net) within one (1) hour of discovery, as mandated by **Policy 06 (Incident Response)**.

5.4.7 ENFORCEMENT

Any user found to have violated this Policy may be subject to disciplinary action, up to and including termination of employment. Cloud Shift reserves the right to revoke remote access privileges at any time if a device or user is deemed a security risk.

6.0 Domain C: Product & Service Operations

6.1 **Policy 08:** Secure Software Development Lifecycle (SSDLC) Policy

Document ID: CLOUD SHIFT-POL-008
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Chief Technology Officer (CTO)
Reference Standards: ISO/IEC 27001:2022 (A.8.25); NIST SP 800-218 (SSDF); OWASP Top 10

6.1.1 PURPOSE

The purpose of this Policy is to integrate information security and privacy principles into every phase of the software development lifecycle at Cloud Shift. It establishes a "Secure by Design" standard for all software products, ensuring that security defects are identified and remediated early in the development process rather than in production.

6.1.2 SCOPE

This Policy applies to all developers, quality assurance (QA) testers, product managers, and DevOps engineers, including full-time employees and third-party contractors. It covers all software code, scripts, Application Programming Interfaces (APIs), and container images developed or maintained by Cloud Shift for *VirtuHire*, *TaskFlow*, *Bison Finsight*, and *Practitioner 360*.

6.1.3 THE SECURE LIFECYCLE PHASES

All software development projects must adhere to the following security gates. Skipping any phase without written authorization from the Chief Information Security Officer (CISO) constitutes a violation of this Policy.

6.1.3.1 Phase 1: Requirements & Design (Threat Modeling) Prior to the commencement of coding for any new module or significant feature, the Engineering Lead must ensure the following:

(a) **Security Requirements Definition:** Security requirements (e.g., "Must support Multi-Factor Authentication," "Must encrypt data at rest") must be defined and documented alongside functional requirements.

(b) **Threat Modeling:** For features involving "Confidential" or "Restricted" data, a Threat Modeling exercise (using methodologies such as STRIDE) must be conducted to identify potential attack vectors.

(c) **Privacy Impact Assessment (PIA):** If the feature involves the collection of new Personal Information (PI), a PIA must be completed in accordance with Policy 01 (Data Privacy).

6.1.3.2 Phase 2: Development (Secure Coding Standards) Developers must adhere to the following mandates during the coding phase:

(a) **OWASP Mitigation:** Code must be written to prevent the Open Web Application Security Project (OWASP) Top 10 vulnerabilities, including but not limited to SQL Injection, Cross-Site Scripting (XSS), and Broken Access Control.

(b) **Input Validation:** All data input from untrusted sources (e.g., user forms, external APIs) must be validated against a strict allowlist of expected formats, types, and lengths.

(c) **Secret Management:** Hardcoding credentials, passwords, API keys, or cryptographic keys in source code is strictly prohibited. All secrets must be injected at runtime via a secure Secrets Manager (e.g., AWS Secrets Manager, HashiCorp Vault).

6.1.3.3 Phase 3: Testing & Verification Security testing must be automated and integrated into the Continuous Integration/Continuous Deployment (CI/CD) pipeline.

(a) **Static Application Security Testing (SAST):** Automated tools must scan source code repositories on every commit to identify security flaws.

(b) **Software Composition Analysis (SCA):** All third-party open-source libraries must be scanned for known vulnerabilities (CVEs). Use of libraries with "Critical" or "High" severity vulnerabilities is strictly prohibited.

(c) **Dynamic Application Security Testing (DAST):** Automated scans of the running application in the Staging environment must be performed prior to any major release.

6.1.3.4 Phase 4: Deployment & Release Code shall not be deployed to the Production environment until it satisfies the following criteria:

(a) **Peer Review:** No code may be merged into the Production branch without a documented review and approval by a second developer ("The Two-Person Rule"). However, Where a second developer is not available, the CTO may provide a 'Manager Approval' to satisfy this requirement.

(b) **Vulnerability Remediation:** All "Critical" and "High" severity vulnerabilities identified during testing must be remediated or formally accepted via a Risk Acceptance Form signed by the CISO.

(c) **Rollback Capability:** Every deployment must have a documented "Back-Out Plan" enabling the team to revert the system to a stable state within a defined Recovery Time Objective (RTO) specific to that service, in the event of a failed deployment.

6.1.3.5 Phase 5: Maintenance & Response

(a) **Vulnerability Disclosure:** Cloud Shift shall maintain a clear process for external security researchers to report vulnerabilities.

(b) **Patch Management:** Critical security patches for underlying infrastructure and dependencies must be applied within 48 hours of release (or the next business day), unless an active exploit is detected in the wild.

6.1.4 ARTIFICIAL INTELLIGENCE (AI) GOVERNANCE

This section applies conditionally and becomes mandatory immediately upon the commencement of High-Impact AI Systems involving Machine Learning (ML), Generative AI, or Automated Decision Systems.

6.1.4.1 AI Development Standards

(a) **Data Provenance:** All data used for training or fine-tuning AI models must be obtained lawfully. The use of scraped data in violation of third-party Terms of Service is strictly prohibited.

(b) **Data Poisoning Prevention:** Training datasets must be stored in immutable (WORM) storage to prevent adversarial tampering or "data poisoning."

(c) **Model Security:** AI models exposed via public APIs must implement rate limiting and input sanitization to prevent "Model Inversion" or "Extraction" attacks.

6.1.4.2 Algorithmic Fairness & Transparency

(a) **Bias Testing:** Prior to deployment, any AI model used for decision-making (e.g., candidate scoring in *VirtuHire*) must undergo statistical testing to detect and mitigate bias against protected groups under the *Canadian Human Rights Act*.

(b) **Explainability:** The development team must document a "Model Card" detailing the model's intended use, limitations, and decision logic to satisfy transparency requirements under the *Artificial Intelligence and Data Act* (AIDA).

6.1.5 MANDATORY SECURITY FEATURES LIST

To ensure a baseline of security, all Cloud Shift applications (*VirtuHire*, *TaskFlow*) must implement the following controls by default:

(a) **Transport Security:** HTTPS (TLS 1.2+) enforced on all external interfaces. HTTP connections must auto-redirect to HTTPS.
(b) **Authentication:** Rate limiting (e.g., max 10 attempts/minute) on all login endpoints to prevent brute force.

(c) **Session Management:** Secure Cookies (Attributes: Secure, HttpOnly, SameSite=Strict) must be used for session tokens.
(d) **Output Encoding:** Context-aware encoding to prevent Cross-Site Scripting (XSS) in all user-facing views.
(e) **Error Handling:** Production errors must display a generic message (e.g., "An error occurred") and must **never** reveal stack traces or database dumps to the user.

6.1.6 ENFORCEMENT

Any attempt to bypass the security controls defined in this Policy (e.g., disabling SAST scanners, force-merging code without review) is a violation of this Policy and may result in disciplinary action, up to and including termination of employment.

6.2 **Policy 09:** Change Management & Deployment Policy

Document ID: CLOUD SHIFT-POL-009
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: VP of Engineering / DevOps Lead
Reference Standards: ITIL v4 (Change Enablement); SOC 2 (CC8.1); ISO/IEC 27001:2022 (A.8.29); NIST SP 800-128

6.2.1 PURPOSE

The purpose of this Policy is to ensure that all changes to Cloud Shift's production environment are assessed, approved, implemented, and reviewed in a controlled manner. This framework minimizes the risk of service disruption, unauthorized system alterations, and security incidents while maintaining the agility required for continuous delivery.

6.2.2 SCOPE

This Policy applies to all "Changes" made to Cloud Shift's Production Infrastructure and Production Applications.

(a) In Scope: All changes to live servers, cloud configurations (AWS/Azure), database schemas, firewall rules, and application code (*VirtuHire*, *TaskFlow*, *Bison Finsight*) deployed to the Production environment.

(b) Out of Scope: Changes made solely within Development, Sandbox, or personal workstation environments that have no connectivity to Production data or networks.

6.2.3 ROLES AND RESPONSIBILITIES

To ensure accountability, the following roles are defined for the Change Management process:

(a) Change Requestor: The individual (typically a Developer or Engineer) who initiates a Change Request (CR) and provides the technical details, risk assessment, and back-out plan.

(b) Change Manager: The designated authority (e.g., DevOps Lead) responsible for the day-to-day operation of the Change Management process, including the initial trait of CRs and convening the Change Advisory Board.

(c) Change Advisory Board (CAB): A cross-functional group responsible for reviewing and authorizing "High Risk" and "Significant" changes. The CAB assesses changes from both a technical and business perspective.

(d) Emergency Change Authority (ECAB): A smaller, specialized subset of the CAB authorized to make rapid decisions during critical outages or security incidents.

6.2.4 CHANGE CLASSIFICATION

All changes must be classified into one of the following categories to determine the required approval workflow:

6.2.4.1 Standard Change

(a) Definition: A low-risk, pre-authorized change that follows a documented, repeatable procedure. These changes are frequent and have a proven history of success.

(b) Examples: Weekly OS security patching, updating antivirus definitions, minor content updates to the public website, scaling up a cloud instance within approved budget limits.

(c) Approval: "Pre-Approved." These do not require specific authorization for each instance, provided they follow the established Standard Operating Procedure (SOP). While the change is pre-authorized, **it must still be logged.**

6.2.4.2 Normal Change

(a) Definition: A non-trivial change that modifies the logic, structure, or configuration of a system. These changes require a specific risk assessment and approval.

(b) Examples: A new feature release for *VirtuHire*, a database schema migration, firewall rule modification, or changing a third-party API integration.

(c) Approval: Requires a formal Change Request (CR) and must be reviewed and approved by a Peer (for Medium Risk) or the CAB (for High Risk) prior to implementation.

6.2.4.3 Emergency Change

(a) Definition: An urgent change required to remediate a critical incident, such as a service outage, a "Zero-Day" security vulnerability, or a major bug affecting data integrity.

(b) Examples: Patching a critical remote code execution vulnerability, rebooting a hung production server, or rolling back a failed deployment that is causing data corruption.

(c) Approval: Approved via the "Emergency Protocol" (See Section 6.0).

6.2.5 THE CHANGE ADVISORY BOARD (CAB)

6.2.5.1 CAB Composition

The CAB shall consist of representatives from the following functions:

(a) Engineering/DevOps: To assess technical feasibility and collision risks.

(b) Security (InfoSec): To review security implications and compliance.

(c) Product Management: To verify alignment with business requirements.

(d) Customer Support: To prepare for potential user impact or support volume.

6.2.5.2 CAB Operations

(a) Meetings: The CAB shall meet weekly (or as required) to review the pending "High Risk" changes.

(b) Quorum: A CAB meeting requires a minimum attendance of the Change Manager plus at least one representative from Engineering and one from Security.

(c) Voting: Decisions are made by consensus. If a consensus cannot be reached, the VP of Engineering holds the tie-breaking vote.

6.2.6 EMERGENCY CHANGE PROTOCOL

To ensure agility during crises without sacrificing accountability:

(a) Verbal Authorization: During a P1 (Critical) Incident, the Incident Commander or VP of Engineering may grant verbal authorization for a change.

(b) Retroactive Documentation: An Emergency Change Request must be opened and documented within twenty-four (24) hours of the incident resolution.

(c) Post-Incident Review: All Emergency Changes are subject to a mandatory Post-Implementation Review (PIR) to ensure the emergency privilege was not abused to bypass standard process.

6.2.7 DEPLOYMENT STANDARDS

6.2.7.1 Segregation of Duties (SoD)

(a) The "Maker-Checker" Rule: To prevent fraud and unauthorized code injection, the individual who develops the code should not be the sole individual with the permission to deploy it to the Production environment.

(b) Pipeline Enforcement: Access to trigger the Production Deployment Pipeline shall be restricted to authorized Release Managers or Tech Leads. Where team size precludes strict physical segregation, automated pipeline logs shall serve as the mitigating control.

6.2.7.2 Rollback (Back-Out) Requirements

(a) Mandatory Fallback: No change shall be approved for deployment without a documented and tested "Back-Out Plan."

(b) Verification: If the deployment fails or triggers critical alerts within the "Post-Deployment Monitoring Period" (typically 1 hour), the Release Manager must immediately execute the Back-Out Plan to restore the system to its previous stable state.

6.2.8 POST-IMPLEMENTATION REVIEW (PIR)

6.2.8.1 Successful Changes

(a) Closure: Upon successful deployment and verification, the Change Request ticket must be marked as "Closed - Successful."

6.2.8.2 Failed Changes

(a) Root Cause Analysis: Any change that results in a service outage or requires a rollback must undergo a Post-Implementation Review (PIR) to identify the root cause of the failure.

(b) Remediation: The findings of the PIR must be recorded, and corrective actions (e.g., updating test cases, fixing deployment scripts) must be assigned to prevent recurrence.

6.2.9 ENFORCEMENT

Unauthorized changes to Production systems (often called "Shadow IT") are a severe violation of this Policy. Any employee found to have bypassed the Change Management process may be subject to disciplinary action, up to and including termination of employment.

6.3 **Policy 10:** Acceptable Use Policy (AUP)

Document ID: CLOUD SHIFT-POL-010
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Human Resources / IT Director
Reference Standards: ISO/IEC 27001:2022 (A.5.10); NIST SP 800-53 (PL-4); SOC 2 (CC6.1)

6.3.1 PURPOSE

The purpose of this Policy is to define the boundaries of acceptable behavior for users of Cloud Shift's information systems. It protects the company from legal liability, reputation loss, and security risks while respecting the privacy and professional autonomy of its employees.

6.3.2 SCOPE

This Policy applies to all "Users," defined as employees, independent contractors, consultants, and third-party personnel who access Cloud Shift equipment (laptops, mobile devices), networks, or data.

6.3.3 GENERAL USE OF ASSETS

6.3.3.1 Company Equipment

(a) Business Use First: Cloud Shift devices and accounts are tools provided primarily for business purposes. Incidental personal use (e.g., checking personal email, banking) is permitted provided it does not interfere with productivity, consume excessive bandwidth, or violate security policies.

(b) No Modification: Users must not disable security controls (e.g., turning off Antivirus/EDR, bypassing the VPN) or install unauthorized software ("Shadow IT") on company-owned devices without prior approval from the IT Department.

6.3.3.2 Contractor & BYOD Security

(a) Personal Device Standard: Users accessing Cloud Shift data or networks via personally owned devices (Bring Your Own Device) must ensure their device maintains an active, updated Antivirus/EDR solution and full-disk encryption.

(b) Integrity: The use of devices with bypassed operating system security controls (e.g., "Jailbroken" iOS or "Rooted" Android devices) to access Cloud Shift data is strictly prohibited.

6.3.3.3 Identity and Access

(a) No Sharing: As defined in Policy 05 (Access Control), users are strictly prohibited from sharing their passwords, Multi-Factor Authentication (MFA) tokens, or SSH keys with anyone, including managers or IT support staff.

(b) Accountability: Users are personally responsible for all activity conducted under their User ID. Leaving a logged-in workstation unlocked and unattended in a public area is a violation of this Policy.

6.3.4 PROHIBITED ACTIVITIES

Users generally **MUST NOT** engage in the following activities on Cloud Shift systems:

(a) Illegal Activities: Using systems to violate any local, provincial, or federal law, including the storage or transmission of illicit material.

(b) Harassment: Transmitting material that is harassing, defamatory, discriminatory, or creates a hostile work environment.

(c) Circumvention: Attempting to bypass network security controls, such as using anonymous proxies or "VPN-over-HTTPS" to evade web filtering.

(d) Cryptomining: Using Cloud Shift hardware or cloud instances (e.g., AWS EC2) for cryptocurrency mining or other unauthorized commercial gain.

6.3.5 DATA PRIVACY AND MONITORING

6.3.5.1 Employee Privacy (Balanced Approach)

(a) Monitoring Scope: Cloud Shift respects employee privacy. The company monitors network traffic (metadata), file access logs, and system health metrics strictly for the purpose of security and operational stability.

(b) No Active Surveillance: Cloud Shift **does not** actively record screen activity, keystrokes, or private messages (e.g., Slack DMs) as a standard practice.

(c) Exception for Cause: Full forensic monitoring (including content review) may be authorized **only** if there is a reasonable, substantiated suspicion of a security breach, data exfiltration, or criminal activity. Such authorization typically requires the joint written approval of the CISO and Legal Counsel.

(d) Emergency Override: In the event of an active, critical security incident where immediate action is required to prevent data loss or significant harm, the CISO may authorize monitoring verbally. This decision must be documented retroactively and submitted to Legal Counsel within twenty-four (24) hours.

6.3.5.2 Expectation of Privacy

(a) Corporate Data: Users should have no expectation of privacy regarding *business data* (e.g., work emails, code commits, documents) stored on Cloud Shift systems. The company reserves the right to access this data for business continuity purposes (e.g., if an employee is unexpectedly absent).

6.3.6 SOCIAL MEDIA AND EXTERNAL COMMUNICATION

6.3.6.1 Professional Conduct

(a) Affiliation: Employees are permitted to identify themselves as Cloud Shift employees on professional networks (e.g., LinkedIn).

(b) Disclaimer: When expressing personal opinions on public forums that could reasonably be attributed to the company, employees must include a disclaimer stating that "The views expressed are my own and do not necessarily reflect those of Cloud Shift."

6.3.6.2 Confidentiality

(a) No Leaks: Employees must strictly avoid discussing internal project code names, unreleased features of *VirtuHire* or *TaskFlow*, or specific client details on social media.

(b) Code Sharing: Posting Cloud Shift source code snippets to public forums (e.g., Reddit, Stack Overflow) to ask for help is strictly prohibited.

6.3.7 USE OF GENERATIVE AI (Third-Party Tools)

To mitigate the risks of data leakage, copyright infringement, and algorithmic bias, all personnel must adhere to the following controls when utilizing Generative AI tools (e.g., LLMs, code copilots, image generators) for Cloud Shift business:

(a) Approved Tools Catalog: Employees may only use Generative AI tools that have been formally vetted and added to the Cloud Shift "Approved Tools Catalog" by the Security Team (e.g., Enterprise agreements with zero-retention policies). The use of unapproved, public-tier AI tools for any business process is strictly prohibited.

(b) Classification & Usage Boundaries: Users must strictly adhere to the Data Classification Strategy (Section 3.1). Data classified as **Confidential (L3)** or **Restricted (L4)**—including Client Data, Source Code, and internal financial records—must **never** be inputted into public or unapproved third-party AI systems.

(c) Data Anonymization and Masking: Prior to inputting any permitted data into an approved AI tool, employees must ensure that all Personally Identifiable Information (PII) and sensitive corporate identifiers are fully anonymized, masked, or redacted.

(d) Human-in-the-Loop (HITL) Verification: AI-generated outputs are subject to hallucination and logical errors. A mandatory "Human-in-the-Loop" review is required. Employees must manually verify the accuracy, security, and IP integrity of AI-generated content before it is committed to production source code, used in critical business decisions, or published in customer-facing applications.

(e) Access Control (RBAC): Access to advanced, data-intensive Enterprise AI models shall be restricted using Role-Based Access Control (RBAC). Licenses and access grants will be provisioned solely based on verified job function and business need, in accordance with Policy 05 (Access Control).

(f) Vendor Risk Assessment (AI Specific): In accordance with Policy 03 (Third-Party Risk), all proposed AI vendors must undergo a rigorous security assessment. Procurement must explicitly verify the vendor's data retention policies, copyright indemnification, and whether customer data is used to train the provider's foundational models.

6.3.8 ENFORCEMENT

(a) Violations: Violation of this Acceptable Use Policy is a serious matter.

(b) Disciplinary Action: Incidents will be investigated by HR and Security. Consequences may range from a verbal warning to termination of employment and, in cases of illegal activity, referral to law enforcement.

6.4 **Policy 11:** Business Continuity & Disaster Recovery Policy

Document ID: CLOUD SHIFT-POL-011
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Chief Operating Officer (COO) / Chief Information Security Officer (CISO)
Reference Standards: ISO 22301 (Business Continuity); NIST SP 800-34 Rev 1; SOC 2 (A1.2, A1.3)

6.4.1 PURPOSE

The purpose of this Policy is to ensure that Cloud Shift possesses the capability to survive a catastrophic event—whether natural, technological, or malicious—and restore Critical Business Functions (CBF) within a pre-defined acceptable timeframe. This framework minimizes financial loss, reputational damage, and legal liability resulting from extended service disruptions.

6.4.2 SCOPE

This Policy applies to the restoration of all information assets, personnel, and operational processes required to deliver Cloud Shift's core services.

(a) In Scope:

- **Production Environments:** Hosting *VirtuHire* and *TaskFlow*.
- **Corporate Systems:** *Bison Finsight* (Financial Data) and *Practitioner 360*.
- **Critical Third-Party Dependencies:** Identity Providers (e.g., Okta/Auth0), Cloud Infrastructure (AWS/Azure), and Source Code Repositories.

(b) Out of Scope:

- Experimental or "Proof of Concept" (PoC) projects not yet released to clients.
- Non-critical development sandboxes.

6.4.3 RECOVERY OBJECTIVES

To guide architectural decisions and investment in redundancy, Cloud Shift has established the following **Target** Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).

(Note: These are objectives, not guarantees. Actual recovery times may vary based on the nature of the disaster and third-party cloud availability.)

6.4.3.1 Impact Tiers and Objectives Table

Tier	Criticality Level	System / Application Scope	Target RTO (Time)	Target RPO (Data Loss)

Tier 1	**Mission Critical**	**Client-Facing Products** • *VirtuHire* (Candidate Data) • *TaskFlow* (Automation Engine) • Production Databases	**Target: 24 Hours** *(Goal for service restoration)*	**Target: 1 Hour** *(Max targeted data loss)*
Tier 2	**Business Essential**	**Internal Corporate Tools** • *Bison Finsight* (Financial Ledgers) • *Practitioner 360* (Partner Portal) • Corporate Email / Slack	**Target: 48 Hours** *(Manual workarounds acceptable)*	**Target: 24 Hours** *(Daily backup)*
Tier 3	**Non-Critical**	**Support Systems** • Development / Staging Environments • Legacy Archives • Marketing Website (Static)	**Best Effort** *(Typically 5-7 Business Days)*	**N/A** *(Data is reproducible)*

6.4.4 CRISIS MANAGEMENT GOVERNANCE

6.4.4.1 The Crisis Management Team (CMT)

(a) Composition: The CMT is the decision-making body responsible for declaring a disaster and coordinating the response. It consists of the CEO, COO, CISO, and VP of Engineering.

(b) Authority: The CMT has the exclusive authority to:

- Formally declare a "Disaster State."
- Authorize emergency spending (e.g., procuring new hardware or cloud instances) without standard procurement approvals.
- Approve communication releases to the press and clients.

6.4.4.2 Disaster Declaration Process

(a) Threshold: A disaster is declared when an incident is expected to exceed the Target RTO of a Tier 1 system (i.e., outage > 24 hours) or when a physical facility is rendered inaccessible.

(b) Activation: Any member of the Senior Leadership Team may convene the CMT to vote on activation.

6.4.5 BACKUP AND RETENTION STRATEGY

6.4.5.1 The "3-2-1" Architecture

To ensure data survivability, the IT team shall adhere to the industry-standard "3-2-1" backup principle:

(a) Three Copies: Maintain at least three copies of the data (1 Live Production Copy + 2 Distinct Backups).

(b) Two Media Types: Store data on at least two different storage media types or distinct storage services (e.g., Production EBS Volumes + S3 Glacier Deep Archive).

(c) One Off-Site: Keep at least one copy in a physically separate location. For Cloud Shift, this mandates cross-region replication (e.g., replicating encrypted backups from ca-central-1 to ca-west-1), subject to data sovereignty compliance reviews.

6.4.5.2 Ransomware Protection (Immutability)

(a) Object Lock: Backups for *Bison Finsight* (Financial Data) and *VirtuHire* must be stored using "Object Lock" (Write Once, Read Many - WORM) technology.

(b) Exemption: The CISO may authorize the deletion of specific WORM-locked archives only if strictly required by law (e.g., a GDPR "Right to Erasure" request) or if authorized by an Executive Exemption to manage excessive cloud storage costs.

(c) Air-Gapping: Where feasible, a "logical air gap" shall be maintained where backup deletion permissions are separated from standard administrative credentials.

6.4.6 DISASTER SCENARIOS AND RESPONSE

The Business Continuity Plan (BCP) must account for the following specific scenarios:

6.4.6.1 Scenario A: Cloud Provider Outage

(a) Risk: A total failure of the primary AWS/Azure Region (e.g., us-east-1 goes offline).

(b) Response: The Engineering Team shall execute the "Region Failover Playbook" to hydrate infrastructure in the secondary region using Infrastructure-as-Code (IaC) templates.

6.4.6.2 Scenario B: Cyber Attack (Ransomware/Wiper)

(a) Risk: Malicious encryption of production data and primary backups.

(b) Response: The Incident Response Team (IRT) shall isolate the environment, scrub the systems, and restore from the immutable (WORM) backups defined in Section 5.2.

6.4.6.3 Scenario C: Loss of Key Personnel

(a) Risk: Unexpected unavailability of key engineers (e.g., the "Bus Factor").

(b) Response: "Runbooks" and technical documentation must be maintained in a central knowledge base (e.g., Confluence) to allow alternate staff to restart services. Access credentials must be retrievable via a "Break-Glass" procedure by the CMT.

6.4.7 EMERGENCY COMMUNICATIONS

6.4.7.1 External Communication (Clients)

(a) Status Page: Cloud Shift shall maintain a public Status Page (hosted on infrastructure separate from the main product) to provide real-time updates.

(b) Embargo: No employee, other than the designated Spokesperson, may communicate with the media regarding a disaster. "No Comment" is the standard response until a statement is approved by Legal Counsel.

6.4.7.2 Internal Communication (Employees)

(a) Call Tree: In the event of a total failure of corporate communication channels (e.g., Slack is down), the CMT shall activate a manual "Phone Call Tree" or use a secondary emergency notification system (e.g., WhatsApp Business) to coordinate staff.

6.4.8 TESTING AND MAINTENANCE

6.4.8.1 Testing Schedule

(a) Full Simulation: The CISO must coordinate a full-scale Disaster Recovery simulation (e.g., restoring the *Bison Finsight* database from backup to an isolated test instance) at least **Annually**.

(b) Tabletop Exercise: A discussion-based simulation involving the CMT and Legal Counsel shall be conducted every **six (6) months** to validate decision-making protocols.

6.4.8.2 Plan Maintenance

(a) Review Cycle: This Policy and the associated technical "Runbooks" must be reviewed and updated **Annually** (to align with the audit cycle) or immediately following any significant infrastructure change or failed test.

6.4.9 ENFORCEMENT

System owners are responsible for ensuring their applications are configured to meet the RTO/RPO targets defined above. Failure to configure backups or participate in mandatory DR testing is a violation of this Policy and may result in disciplinary action.

6.5 **Policy 12**: Digital Accessibility & Inclusion Policy

Document ID: CLOUD SHIFT-POL-012
Version: 1.0
Effective Date: March 03, 2026
Policy Owner: Human Resources Specialist
Reference Standards: AODA (Ontario), WCAG 2.1 Level AA, Quebec Charter of the French Language, ACA (Accessible Canada Act)

6.5.1 PURPOSE

The purpose of this Policy is to ensure that Cloud Shift's digital products, workplace, and services are barrier-free and accessible to persons with disabilities. It codifies our legal obligation to treat all individuals with dignity and independence, while complying with Canadian bilingualism mandates.

6.5.2 SCOPE

This policy applies to:

(a) **Digital Assets:** Public websites, the *VirtuHire* and *Practitioner 360* platforms, and mobile applications.

(b) **Content:** Electronic documents (PDFs, Decks) distributed externally.

(c) **Support:** Customer Service and Technical Support channels.

6.5.3 ACCESSIBILITY STANDARDS (AODA & WCAG)

6.5.3.1 Technical Standard

(a) **WCAG Alignment:** All external web content and product interfaces shall be designed and maintained to meet the **Web Content Accessibility Guidelines (WCAG) 2.1 Level AA**.

(b) **Quality Assurance:** Accessibility testing (using screen readers like NVDA or VoiceOver) must be integrated into the QA process defined in Policy 08 (SSDLC) before any major release.

6.5.3.2 Feedback Process

(a) **Mechanism:** Cloud Shift shall maintain a publicly available method (e.g., specific email or web form) for users to report accessibility barriers.

(b) **Response:** All accessibility-related feedback must be acknowledged within **48 hours**, and a remediation plan or alternative format must be provided without undue delay.

6.5.4 OPERATIONAL REQUIREMENTS

6.5.4.1 Training (Mandatory)

(a) **Requirement:** All employees, volunteers, and contractors must complete **Accessibility Training** (covering AODA and the Human Rights Code) within 30 days of hire.

(b) **Records:** HR must maintain records of dates and completion status for audit purposes.

6.5.4.2 Procurement

(a) **Vendor Vetting:** When purchasing third-party software or tools (e.g., a new HR portal), the procurement team must request an **Accessibility Conformance Report (ACR)** or VPAT to verify the tool is usable by employees with disabilities.

(b) **Exemption:** Where an ACR is unavailable (e.g., small vendors), the CISO or CPO may approve the purchase via a Risk Acceptance Form, provided the tool is not client-facing.

6.5.4.3 Accessible Formats

(a) **Documents:** All public-facing PDFs, slide decks, and reports generated by Cloud Shift must be "Tagged" and readable by assistive technology. Sending flat "image-only" PDFs to clients is prohibited.

6.5.5 BILINGUAL SUPPORT (QUEBEC LAW 25 & CHARTER)

A*pplicable when Cloud Shift conducts business within the Province of Quebec.*

To comply with the *Charter of the French Language*:

(a) **Interfaces:** Any software interface available to the general public in Canada (*VirtuHire*) must be available in French. The French version must be functionally equivalent to the English version.

(b) **Transition Clause:** Cloud Shift commits to achieving full bilingualism by Q4 2026. Until such time, users may request manual assistance in French via the support channel.

(c) **Best Effort Support:** Customers interacting with Cloud Shift support will be provided with service in French on a best effort basis until Cloud Shift can provide bilingual services, English and French, on a permanent, ongoing basis.

6.5.6 ENFORCEMENT

(a) **Release Blocker:** New product features that fail to meet WCAG 2.1 AA standards shall be classified as "Critical Defects" and blocked from release until remediated.

(b) **Security Override:** The "Release Blocker" rule does not apply to Critical Security Hotfixes. In such cases, the security patch may be released immediately, with accessibility remediation to follow within 14 days.

(c) **Non-Compliance:** Failure to complete mandatory accessibility training may result in disciplinary action.

PART 3: PROCEDURES REGISTRY (APPENDICES)

A directory of the operational documents. This section does not contain the full text but points to where the live technical documents exist.

7.0 Technical Standards Registry

This section enumerates the specific technical configuration documents that enforce the policies defined in Part 2. These documents are maintained by the Engineering Team and are subject to quarterly technical review.

Ref ID	Standard Name	Owner	Regulatory Mapping	Description
STD-01	**Encryption & Key Management Standard**	CISO	PIPEDA, SOC 2 (CC6.1)	Defines the specific algorithms (e.g., AES-256, RSA-2048) and rotation schedules for KMS keys used in *VirtuHire* and *Bison Finsight*.
STD-02	**Cloud Configuration Baseline (AWS/Azure)**	DevOps Lead	ISO 27001 (A.8.9)	Defines the "Golden Image" settings for EC2/VMs, S3 Buckets (Public Access Block), and Security Groups to ensure the "Fortress Model" is technically enforced.
STD-03	**Workstation Hardening Standard (BYOD)**	IT Director	NIST 800-53 (CM-6)	Specifies the mandatory configuration for personal devices (e.g., BitLocker enabled, Screen Lock 15 mins, Guest accounts disabled) before network access is granted.
STD-04	**Logging & Monitoring Standard**	SecOps	SOC 2 (CC7.1)	details which specific events (e.g., ConsoleLogin, DeleteBucket) must trigger High-Severity alerts in the SIEM.

8.0 Operational Playbooks

This section lists the "How-To" manuals for critical security operations. These are living documents used during active incidents.

Ref ID	Playbook Name	Owner	Activation Trigger
PB-01	**Incident Response Playbook**	Incident Cmdr	Detection of a confirmed Security Incident (e.g., Ransomware, Data Exfiltration). Contains the specific "Call Tree" and forensic command syntax.

PB-02	**Data Subject Access Request (DSAR) Procedure**	Privacy Officer	Receipt of a request from a user (Candidate or Employee) to view or delete their data under GDPR/PIPEDA.
PB-03	**Vendor Security Assessment Procedure**	CISO	Procurement of a new software tool. Details the scoring matrix for the Vendor Risk Assessment.
PB-04	**Disaster Recovery Runbook (Region Failover)**	VP Engineering	Total loss of primary AWS Region. Contains the Terraform/IaC scripts to hydrate the secondary region.

9.0 Forms & Templates

Mandatory records used to demonstrate compliance during an audit.

- **FORM-01:** Privacy Impact Assessment (PIA) Template
- **FORM-02:** Vendor Security Questionnaire (VSQ)
- **FORM-03:** Risk Acceptance Form (RAF)
- **FORM-04:** Change Request (CR) Ticket Template
- **FORM-05:** Security Incident Report Form

10.0 Acronyms

To ensure legal precision, the following terms are defined for this Framework.

- **AIDA:** Artificial Intelligence and Data Act (Proposed Canadian legislation).
- **BYOD:** Bring Your Own Device (Employee-owned hardware used for work).
- **CAB:** Change Advisory Board.
- **CISO:** Chief Information Security Officer.
- **CMT:** Crisis Management Team.
- **DPA:** Data Processing Agreement (Contractual addendum regarding privacy).
- **GDPR:** General Data Protection Regulation (EU).
- **IdP:** Identity Provider (e.g., Okta, Google Workspace).
- **MFA:** Multi-Factor Authentication.
- **PI / PII:** Personal Information / Personally Identifiable Information.
- **PIA:** Privacy Impact Assessment.
- **PIPEDA:** Personal Information Protection and Electronic Documents Act (Canada).
- **RPO:** Recovery Point Objective (Max allowable data loss).

- **RTO:** Recovery Time Objective (Target time to restore service).
- **SOC 2:** System and Organization Controls 2 (Audit standard).
- **SSDLC:** Secure Software Development Lifecycle.
- **WORM:** Write Once, Read Many (Immutable storage).